ITU-MiniTwit Report

BSc Group G
DevOps, Software Evolution and Software Maintenance
BSDSESM1KU

Emilie Bliddal Ravn Larsen (emrl@itu.dk)
Jacob Folkmann (jafo@itu.dk)
Jacob Hørberg (jacho@itu.dk)
Joakim-David (jpre@itu.dk)
Rasmus Bondo (rabh@itu.dk)

Spring 2026

Contents

1 System's Perspective **1**
1.1 Design and Architecture . . . 1
1.2 Dependencies . . . 2

2 Process' Perspective **2**
2.1 CI/CD Chains . . . 2
2.2 Monitoring . . . 2
2.2.1 What we log from chirp . . . 3
2.2.2 Alloy . . . 3
2.3 Security Assessment . . . 3
2.4 Availability and Scaling . . . 4

3 Reflection Perspective **4**
3.1 Evolution and Refactoring . . . 4
3.2 operation . . . 4
3.3 maintenance . . . 5

4 Use of generative AI **5**
4.1 References . . . 5

1 System's Perspective

1.1 Design and Architecture

TODO: Design and architecture of your ITU-MiniTwit systems.

1.2 Dependencies

TODO: All dependencies of your ITU-MiniTwit systems on all levels of abstraction and development stages. That is, list and briefly describe all technologies and tools you applied and depend on.

The Chirp application is built on .NET 9.0 with ASP.NET Core (Razor Pages). Entity Framework Core 9.0 is used as the ORM, backed by PostgreSQL 17 in production and SQLite for local development. Authentication is
handled by ASP.NET Identity for local accounts and GitHub OAuth for third-party login.

The application runs in a Docker container (runtime image aspnet:9.0-noble-chiseled) and is deployed as a Docker Swarm stack on a DigitalOcean Droplet. Infrastructure is provisioned with Terraform, including a
managed PostgreSQL cluster and a reserved IP. The observability stack consists of Prometheus for metrics, Grafana Alloy for log collection, Loki for log storage, and Grafana for visualization.

CI/CD is handled by GitHub Actions. Pipelines cover building, testing, and deploying to Docker Swarm via Docker Hub. Security tooling includes CodeQL for static analysis, Trivy for container image scanning, Hadolint for Dockerfile linting, and ShellCheck for shell script linting. The report itself is built from Markdown to PDF using Pandoc.

Testing uses xUnit and NUnit for unit and integration tests, Coverlet for code coverage, and Playwright for end-to-end browser testing. ## Current State of the System TODO: Describe the current state of your systems, for example using results of static analysis and quality assessments.

2 Process' Perspective

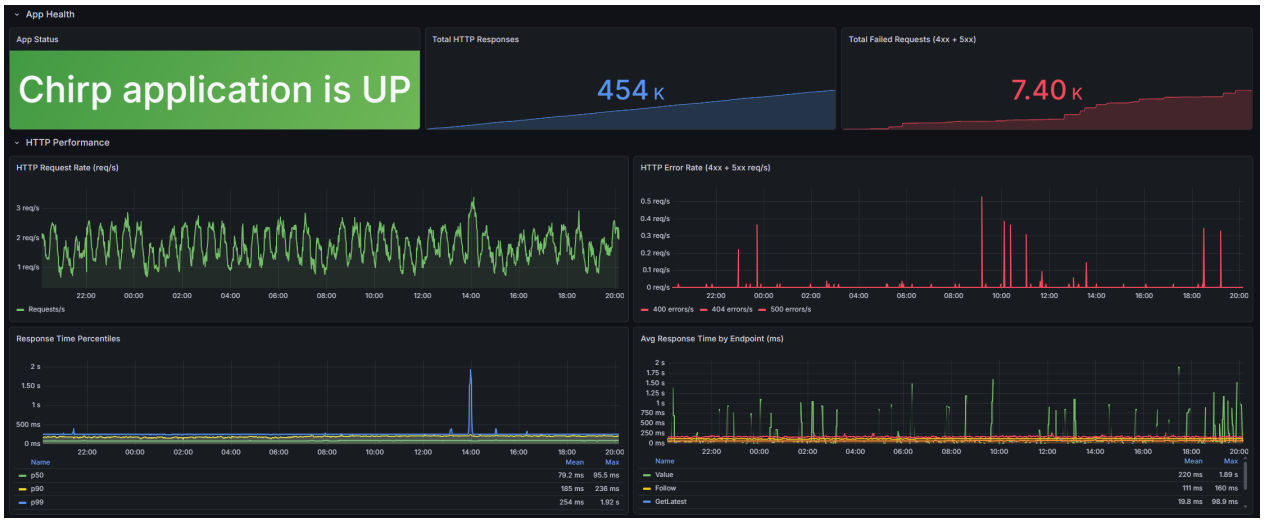
TOBEDELETED: This perspective should clarify how code or other artifacts come from idea into the running system and everything that happens on the way.

2.1 CI/CD Chains

TODO: A complete description and illustration of stages and tools included in the CI/CD pipelines, including deployment and release of your systems.

2.2 Monitoring

TODO: How do you monitor your systems and what precisely do you monitor? Our Chirp application's monitoring stack consists of Prometheus, Grafana, Loki and Grafana Alloy. These are deployed as services within the Docker Swarm. All configuration regarding the monitoring stack is stored as code and updated automatically on every push to main via the Continuous_Deployment_Swarm.yml workflow. The application is setup for whitebox monitoring. It exposes a /metrics endpoint from which Prometheus pulls data every five seconds. Custom metrics include HTTP request counts and response durations, CPU load, working memory and business-level counters. The Grafana dashboard is organised into four sections across three figures.



App Health and HTTP Performance is the primary operational view, that shows live app status. It includes panels for HTTP request rates per second and HTTP error rates second, broken down by 4xx and 5xx status codes, which gives immediate visibility into load and fault distribution. ## Logging Our Logs are displayed on our grafana webserver where they can be view under drilldown/logs. We use a stack compromised by grafana, loki and alloy. Alloy is used to collect the logs from the docker containers on the droplet and then ships them to Loki. Loki then stores and index the logs and in the end grafana then uses loki as a datasource to visualise the logs and makes them easily accessible to search and discover.

The logs are aggregated so we have logs from each of the individual chirp servers, Loki, grafana and prometheus.

2.2.1 What we log from chirp

In program.cs we log every incoming request including the method, path, status code, duration and IP.

2.2.2 Alloy

With grafana alloy we collect all stdout/stderr from every docker container on the droplet. This includes logs from exceptions and the chirp application ### Aggregation The logs from our two chirp webservers is aggregated under one handle otherwise it is also possible to search the individual containers.

TODO: What do you log in your systems and how do you aggregate logs?

2.3 Security Assessment

Our application utilizes an automated CI/CD pipeline to continuously harden the system and ensure vulnerabilities are not introduced during development.

The pipeline uses four Automated Quality Gates CodeQL, Trivy, Hadolint and shellcheck.

CodeQL - our SAST tool, which notified the developers about a vulnerability to Cross-Site Scripting (XSS) attacks caused by unsanitized user input in Request.Query["search"]. This vulnerability was patched by applying System.Net.WebUtility.HtmlEncode() to ensure the input is treated as plain text rather than exceutable code.

Trivy - our Software Composition Analysis (SCA) tool and vulnerability scanner. Initial scans of our standard Docker base images revealed an unnecessarily large attack surface. To mitigate this, we transitioned to the minimal aspnet:9.0-noble-chiseled base image, which removes standard OS utilities (like bash) to restrict attacker mobility. Trivy now acts as a strict quality gate by enforcing an –exit-code 1 policy, blocking deployments if any high or critical vulnerabilities are detected.

Hadolint - our Dockerfile linter. It continuously audits our container configurations to enforce best practices, such as ensuring the application runs exclusively as the non-root app user. To enforce these standards over time, it is integrated into our pipeline as a strict checkpoint that fails the build if any warnings occur.

ShellCheck - our shell script linter. It acts as an automated quality safeguard by scanning our deployment scripts for syntax errors, deprecated commands, and security flaws like injection vulnerabilities. This guarantees that our infrastructure-as-code is both secure and reliable prior to deployment.

2.4 Availability and Scaling

TODO: How do you handle availability and scaling in your systems?

Our application runs on a single DigitalOcean droplet using Docker Swarm, which orchestrates two replicas of our Chirp container, each capped at 200 MB of memory. Swarm's built-in load balancer distributes incoming requests evenly across both replicas, and all services are configured with restart_policy: on-failure, so the swarm manager automatically restarts any failed container. A DigitalOcean reserved IP is assigned to the droplet via Terraform, ensuring a stable endpoint even if the underlying VM is replaced.

We have applied both vertical and horizontal scaling. We vertically scaled our managed PostgreSQL cluster by upgrading from 1 GB to 2 GB of RAM, which improved query performance. We horizontally scaled the application layer by moving from a single container to two Swarm replicas. The entire infrastructure — droplet, database cluster, firewall rules, and reserved IP is defined in Terraform and can be reproduced from scratch with a single terraform apply.

The main limitation is single points of failure: we rely on one droplet and one database node. Adding a database replica would be the highest-value improvement, both for data redundancy and because the database is the primary performance bottleneck.

3 Reflection Perspective

TOBEDELETED: Describe the biggest issues, how you solved them, and which are major lessons learned with regards to:

3.1 Evolution and Refactoring

TODO: Describe the biggest issues, interactions, and bugs during the project. NOTE: convert from old chirp to new thing with API NOTE: Migration to postgres

3.2 operation

TODO: From docker compose to terraform and docker swarm.

3.3 maintenance

TODO:

4 Use of generative AI

TOBEDELETED: ITU's rules on the use of generative AI apply for this report too. They are described here and in detail here. Please follow them. For your report that means that you have to state which generative AI tools have been used for which task(s) in your projects. Additionally, describe how generative AI tools have been used and briefly reflect and discuss how they supported or hindered your work process. NOTE: like 2 senteces about this

4.1 References

- **Repository:** https://github.com/Joakim-David/GruppeOG
- **Chirp URL:** https://chirpitu.live
- **Monitoring:** Grafana at `http://209.38.190.12:3000`
- **Issue Tracker:** https://github.com/Joakim-David/GruppeOG/issues